

Polityki bezpieczeństwa

Organizacja „Northbridge Finance” (fikcyjna)

Framework zgodny z ISO/IEC 27001:2022 (Annex A)

AUTOR Bartłomiej Kapała

WERSJA 1.0

KLASYFIKACJA Wewnętrzny

CYKL PRZEGLĄDU coroczny lub po istotnym incydencie

1. Streszczenie wykonawcze

Celem projektu było opracowanie zestawu podstawowych polityk bezpieczeństwa dla fikcyjnej organizacji Northbridge Finance. Firma działa w sektorze finansowym, przetwarza dane klientów i wykorzystuje środowisko chmurowe oraz systemy biurowe i operacyjne, dlatego wymaga spójnego podejścia do ochrony tożsamości, kontroli dostępu, szyfrowania oraz reagowania na incydenty.

W ramach projektu przygotowano uproszczony, ale praktyczny framework polityk, który może stanowić podstawę do dalszego rozwoju dojrzałości organizacji w obszarze cyberbezpieczeństwa. Każda polityka została zmapowana do konkretnych kontroli ISO/IEC 27001:2022 (Annex A).

Głównym celem polityk jest ograniczenie ryzyka nieautoryzowanego dostępu, wycieku danych, nadużyć uprawnień oraz opóźnionej reakcji na zagrożenia.

2. Cel dokumentu

- Zdefiniowanie podstawowych zasad bezpieczeństwa w organizacji.
- Ujednolicenie sposobu zarządzania dostępem i ochroną danych.
- Wskazanie ról i odpowiedzialności związanych z bezpieczeństwem.
- Ustanowienie minimalnych wymagań dotyczących reagowania na incydenty.

- Wsparcie organizacji w ograniczaniu ryzyk operacyjnych i bezpieczeństwa.

3. Zakres

- Zarządzanie tożsamością i kontami użytkowników.
- Kontrola dostępu do systemów i danych.
- Szyfrowanie danych w spoczynku i w transmisji.
- Wykrywanie i reagowanie na incydenty bezpieczeństwa.
- Monitoring, logowanie i audyt działań użytkowników oraz systemów.

Zakres obejmuje wszystkich pracowników, administratorów, kontraktorów oraz systemy przetwarzające dane organizacji.

4. Opis organizacji

Northbridge Finance to fikcyjna organizacja z sektora finansowego zatrudniająca około 200 pracowników. Firma korzysta z:

- środowiska Microsoft 365,
- centralnego katalogu tożsamości,
- systemu CRM,
- aplikacji webowej dla klientów,
- stacji roboczych pracowników,
- rozwiązań chmurowych do przechowywania danych i backupów.

Organizacja przetwarza dane klientów, informacje finansowe oraz dokumenty wewnętrzne, dlatego wymaga podwyższonego poziomu ochrony informacji.

5. Założenia bezpieczeństwa

- Bezpieczeństwo jest obowiązkiem całej organizacji.
- Dostęp do danych powinien być ograniczony do minimum niezbędnego do pracy (least privilege).
- Wszystkie działania w systemach powinny być możliwe do monitorowania.
- Dane wrażliwe muszą być chronione technicznie i organizacyjnie.
- Incydenty bezpieczeństwa powinny być wykrywane i obsługiwane według ustalonego procesu.

6. Polityki bezpieczeństwa (ISO/IEC 27001:2022)

Każda zasada poniżej jest opatrzona identyfikatorem kontroli Annex A (kolor niebieski). Numery zweryfikowano względem ISO/IEC 27001:2022.

6.1 Polityka zarządzania tożsamością (IAM)

Cel

Zapewnienie, że każda osoba korzystająca z zasobów organizacji posiada unikalną, identyfikowalną tożsamość oraz odpowiednio zarządzany dostęp.

Zasady

1. **A.5.16** *Identity management* — Każdy użytkownik musi posiadać indywidualne konto.

2. [A.5.15 Access control](#) · [A.8.5 Secure authentication](#) — Zabrania się współdzielenia kont użytkowników.
3. [A.8.2 Privileged access rights](#) — Konta uprzywilejowane muszą być oddzielone od kont standardowych.
4. [A.5.16 Identity management](#) · [A.6.1 Screening](#) — Proces tworzenia kont musi być powiązany z procesem onboardingu pracownika.
5. [A.6.5 Responsibilities after termination](#) — Usuwanie lub blokowanie kont musi następować niezwłocznie po zakończeniu współpracy.
6. [A.5.18 Access rights](#) — Wszystkie konta uprzywilejowane muszą być regularnie przeglądane.
7. [A.8.5 Secure authentication](#) — Dla wszystkich użytkowników wymagane jest MFA, w szczególności dla administratorów i dostępu do danych wrażliwych.
8. [A.5.17 Authentication information](#) — Hasła muszą spełniać minimalne wymagania długości i złożoności zgodnie z polityką organizacji.

Kontrole: *centralny katalog użytkowników · MFA · regularny przegląd kont · automatyzacja onboardingu i offboardingu*

6.2 Polityka kontroli dostępu

Cel

Ograniczenie dostępu do systemów i danych wyłącznie do osób, które rzeczywiście go potrzebują.

Zasady

9. [A.5.15 Access control](#) · [A.5.18 Access rights](#) — Dostęp przyznawany jest zgodnie z zasadą least privilege.
10. [A.5.15 Access control](#) · [A.8.2 Privileged access rights](#) — Dostęp oparty jest na rolach, zgodnie z modelem RBAC.
11. [A.8.3 Information access restriction](#) · [A.8.24 Use of cryptography](#) — Dostęp do danych wrażliwych wymaga dodatkowej autoryzacji.
12. [A.5.16 Identity management](#) · [A.8.2 Privileged access rights](#) — Dostępy tymczasowe muszą mieć określony termin ważności.
13. [A.5.18 Access rights](#) — Uprawnienia użytkowników powinny być przeglądane cyklicznie, co najmniej raz na 90 dni.
14. [A.8.2 Privileged access rights](#) — Dostępy administracyjne powinny być przyznawane tylko w uzasadnionych przypadkach.
15. [A.8.16 Monitoring activities](#) · [A.8.2 Privileged access rights](#) — Konta serwisowe powinny być monitorowane i ograniczane do konkretnych funkcji.

Kontrole: *role i grupy dostępu · okresowe recertyfikacje uprawnień · kontrola dostępu do zasobów krytycznych · rejestracja działań administracyjnych*

6.3 Polityka szyfrowania danych

Cel

Ochrona poufności danych organizacji zarówno podczas przechowywania, jak i przesyłania.

Zasady

16. [A.8.24 Use of cryptography](#) · [A.8.21 Security of network services](#) — Dane w transzycie muszą być chronione przy użyciu protokołów szyfrowanych (TLS 1.2 lub nowszy).
17. [A.8.24 Use of cryptography](#) — Dane w spoczynku powinny być szyfrowane silnymi algorytmami (np. AES-256).
18. [A.8.13 Information backup](#) · [A.8.24 Use of cryptography](#) — Backupy muszą być szyfrowane.

19. [A.8.24](#) *Use of cryptography* — Klucze kryptograficzne muszą być przechowywane i zarządzane w bezpieczny sposób (zarządzanie kluczami).
20. [A.7.10](#) *Storage media* · [A.5.12](#) *Classification of information* — Zabrania się przechowywania wrażliwych danych w postaci jawnej w nieautoryzowanych lokalizacjach.
21. [A.7.10](#) *Storage media* — Nośniki przenośne zawierające dane organizacji muszą być szyfrowane.

Kontrole: szyfrowanie dysków · szyfrowanie baz danych · szyfrowanie kopii zapasowych · centralne zarządzanie kluczami

6.4 Polityka reagowania na incydenty

Cel

Zapewnienie szybkiego wykrywania, analizy i obsługi incydentów bezpieczeństwa w celu ograniczenia skutków dla organizacji.

Zasady

22. [A.5.24](#) *Information security event reporting* — Każdy incydent bezpieczeństwa musi zostać zgłoszony do zespołu bezpieczeństwa.
23. [A.5.25](#) *Assessment of and decision on events* — Organizacja utrzymuje formalny proces Incident Response.
24. [A.5.26](#) *Response to incidents* — Każdy incydent powinien przejść przez etapy: identyfikacja, analiza, containment, eradication, recovery, lessons learned.
25. [A.5.26](#) *Response to incidents* — Dla najczęstszych scenariuszy muszą istnieć playbooki (phishing, malware, account compromise, suspicious login, data leak).
26. [A.5.25](#) *Assessment of and decision on events* — Incydenty powinny być klasyfikowane według wpływu i priorytetu.
27. [A.5.27](#) *Learning from incidents* — Po każdym istotnym incydencie należy przygotować raport końcowy.

Kontrole: SIEM · EDR · alerting · playbooki operacyjne · procedura eskalacji

6.5 Polityka logowania i monitoringu

Cel

Zapewnienie widoczności działań w systemach i umożliwienie wykrywania nadużyć oraz incydentów.

Zasady

28. [A.8.15](#) *Logging* — Krytyczne systemy muszą rejestrować zdarzenia bezpieczeństwa.
29. [A.8.15](#) *Logging* — Logi powinny obejmować co najmniej: logowania i nieudane logowania, zmiany uprawnień, działania administracyjne, zdarzenia endpointowe, alerty bezpieczeństwa.
30. [A.8.16](#) *Monitoring activities* — Logi powinny być centralizowane w systemie SIEM.
31. [A.8.15](#) *Logging* · [A.5.34](#) *Privacy and protection of PII* — Retencja logów powinna odpowiadać wymaganiom biznesowym i regulacyjnym.
32. [A.8.15](#) *Logging* — Logi muszą być zabezpieczone przed nieautoryzowaną modyfikacją (integralność zapisów).

Kontrole: centralizacja logów · alerty korelacyjne · dashboardy bezpieczeństwa · regularna analiza zdarzeń

6.6 Polityka ochrony stacji roboczych i endpointów

Cel

Ograniczenie ryzyka infekcji, nadużyć i nieautoryzowanego użycia urządzeń końcowych.

Zasady

33. [A.8.7](#) *Protection against malware* — Wszystkie stacje robocze muszą posiadać aktualne oprogramowanie EDR/AV.
34. [A.8.8](#) *Management of technical vulnerabilities* — Systemy operacyjne i aplikacje muszą być regularnie aktualizowane.
35. [A.8.9](#) *Configuration management* · [A.8.7](#) *Protection against malware* — Makra i skrypty muszą być ograniczane zgodnie z polityką bezpieczeństwa.
36. [A.8.18](#) *Use of utility programs* · [A.8.9](#) *Configuration management* — Użytkownicy nie mogą instalować nieautoryzowanego oprogramowania.
37. [A.8.1](#) *User endpoint devices* · [A.7.7](#) *Clear desk and clear screen* — Urządzenia muszą być zabezpieczone hasłem, szyfrowaniem i blokadą ekranu.

Kontrole: EDR · patch management · application control · hardening systemów

6.7 Polityka świadomości bezpieczeństwa

Cel

Zmniejszenie ryzyka błędów ludzkich przez edukację użytkowników.

Zasady

38. [A.6.3](#) *Awareness, education and training* — Wszyscy pracownicy muszą przejść szkolenie z cyberbezpieczeństwa.
39. [A.6.3](#) *Awareness, education and training* · [A.5.7](#) *Threat intelligence* — Organizacja powinna regularnie prowadzić kampanie phishing awareness.
40. [A.5.24](#) *Information security event reporting* — Użytkownicy powinni znać sposób zgłaszania podejrzanych wiadomości i zdarzeń.
41. [A.6.3](#) *Awareness, education and training* — Szkolenia powinny być odnawiane okresowo.

Kontrole: szkolenia onboardingowe · testy phishingowe · materiały edukacyjne · raportowanie wyników kampanii

7. Role i odpowiedzialności

ROLA	ODPOWIEDZIALNOŚĆ
Zarząd	Zatwierdza główne kierunki bezpieczeństwa; wspiera wdrożenie polityk.
Security Officer / Manager	Nadzór nad politykami; inicjuje przeglądy i aktualizacje dokumentów.
SOC / Zespół bezpieczeństwa	Monitoruje zdarzenia; analizuje alerty; prowadzi reakcję na incydenty.
Administratorzy IT	Wdrażają kontrole techniczne; zarządzają kontami, systemami i konfiguracjami.
Użytkownicy końcowi	Stosują się do polityk; zgłaszają incydenty i podejrzane aktywności.

8. Procesy operacyjne

8.1 Onboarding

- Tworzenie konta · przypisanie odpowiedniej roli · aktywacja MFA · szkolenie bezpieczeństwa.

8.2 Offboarding

- Natychmiastowa blokada kont · odebranie uprawnień · zwrot urządzeń · archiwizacja dostępu zgodnie z polityką.

8.3 Przegląd uprawnień

- Cykliczna recertyfikacja dostępów · przegląd kont uprzywilejowanych · usuwanie nadmiarowych uprawnień.

8.4 Obsługa incydentu

- Zgłoszenie · triage · analiza · containment · eradication · recovery · raport i lessons learned.

9. Monitoring i audyt

Organizacja powinna prowadzić regularny monitoring bezpieczeństwa i audyty obejmujące:

- konta użytkowników i administratorów,
- zgodność z politykami dostępu,
- stan aktualizacji systemów,
- status EDR i AV,
- jakość logowania i korelacji,
- gotowość do reagowania na incydenty.

Audyty powinny być przeprowadzane okresowo, a ich wyniki powinny prowadzić do działań naprawczych.

10. Rekomendacje

42. Wdrożyć centralny system IAM z wymuszonym MFA.
43. Ustandaryzować nadawanie dostępów w modelu RBAC.
44. Zintegrować logi tożsamości, endpointów i systemów krytycznych w SIEM.
45. Wdrożyć EDR na wszystkich stacjach roboczych i serwerach.
46. Ograniczyć użycie makr, skryptów i nieautoryzowanych aplikacji.
47. Wdrożyć szyfrowanie danych i backupów jako standard.
48. Utworzyć formalne playbooki reagowania na incydenty.
49. Wdrożyć regularne szkolenia pracowników i symulacje phishingowe.
50. Prowadzić cykliczne przeglądy dostępów i kont uprzywilejowanych.
51. Aktualizować polityki minimum raz w roku lub po istotnym incydencie.

11. Wnioski końcowe

Opracowany framework stanowi podstawowy, ale praktyczny zestaw polityk bezpieczeństwa dla organizacji przetwarzającej dane wrażliwe. Dokument obejmuje kluczowe obszary wpływające na bezpieczeństwo operacyjne: zarządzanie tożsamością, kontrolę dostępu, ochronę danych, monitoring i reagowanie na incydenty.

Wdrożenie opisanych zasad pozwoliłoby organizacji ograniczyć ryzyko kompromitacji kont, nadużyć uprawnień, wycieku danych i opóźnionej reakcji na zagrożenia. Mapowanie każdej zasady do konkretnej kontroli ISO/IEC 27001:2022 umożliwia wykorzystanie dokumentu jako punktu wyjścia do formalnego wdrożenia ISMS.

12. Załączniki

12.1 Polityki do rozwinięcia w przyszłości

- Password Policy · Acceptable Use Policy · Backup Policy
- Remote Access Policy · Vendor Access Policy · Data Classification Policy

12.2 Technologie wspierające

- Azure AD / Entra ID · Microsoft Defender
- Splunk / ELK / Sentinel · BitLocker / FileVault · KMS / HSM · Email Security Gateway

Dokument dydaktyczny — framework polityk zmapowany do ISO/IEC 27001:2022 Annex A. Organizacja fikcyjna.